Projeto 1: ROPA da Sorriso & Saúde Clinitec LTDA.

Oct 6, 2026 Diogo Bandeira

Este inventário é uma simulação para portfólio, com empresa, pessoas e fornecedores fictícios e sem dados reais. A versão 1.1 corrige citações legais e unifica bases legais, prazos e plano de ação.

1. Empresa fictícia

- **Empresa:** Sorriso & Saúde Clinitec LTDA., clínica odontológica de médio porte (clínica geral, ortodontia, odontopediatria e implantes).
- **Quadro:** 18 colaboradores (6 cirurgiões-dentistas, 4 auxiliares de saúde bucal, 4 recepcionistas, 2 no financeiro/RH, 1 gerente administrativo e 1 de TI/Facilities).
- **Áreas:** Atendimento/Recepção, Corpo Clínico, RH/DP, Financeiro, Marketing, Segurança Patrimonial, Qualidade e Jurídico/Compras.

2. Inventário de dados pessoais (ROPA)

#	Processo e área	Categorias de dados	Sensível?	Titulares	Finalidade	Base legal principal (LGPD)	Destinatários	Armazenamento	Retenção	Medidas de segurança	Transf. int.?	Risco
1	Agendamento e pré-cadastro (Recepção)	Nome, CPF, e-mail, telefone, motivo da consulta, idade	Não	Pacientes adultos e crianças/adolescentes (via responsáveis)	Marcar e gerir consultas	Art. 7º, V; Art. 14 (melhor interesse)	Recepção e dentistas	SaaS de gestão odontológica (AWS Brasil)	Vínculo + 5 anos	RBAC, MFA	Não	Baixo
2	Anamnese e prontuário odontológico (Corpo Clínico)	Histórico de saúde, exames, alergias, medicações, odontograma	Sim (saúde)	Pacientes adultos e crianças/adolescentes (via responsáveis)	Prestação de serviço de saúde e diagnóstico	Art. 11, II, 'f'; Art. 14 (melhor interesse)	Dentistas e ASB	Prontuário eletrônico + arquivo físico em sala restrita	Mínimo de 20 anos após o último registro (Lei 13.787/2018, art. 6º)	Criptografia em repouso; controle de chaves do arquivo físico	Não	Alto
3	Faturamento, cobrança e NF (Financeiro)	Nome, CPF, endereço, dados de pagamento, valor pago	Não	Pacientes ou responsáveis legais	Emissão de nota fiscal e cobrança	Art. 7º, II (obrigação legal/tributária)	Financeiro, contabilidade externa, Fisco	ERP financeiro + gateway de pagamento	5 anos (CTN, art. 174)	TLS, tokenização PCI-DSS	Não	Médio

#	Processo e área	Categorias de dados	Sensível?	Titulares	Finalidade	Base legal principal (LGPD)	Destinatários	Armazenamento	Retenção	Medidas de segurança	Transf. int.?	Risco
4	Folha de pagamento e benefícios (RH)	Nome, CPF, RG, CTPS, dados bancários, dependentes, ASO	Sim (ASO)	Funcionários e dependentes (inclusive menores)	Contrato de trabalho e obrigações trabalhistas	Art. 7º, II (dados comuns); Art. 11, II, 'a' (ASO)	RH, consultoria externa, operadora de plano, eSocial	Servidor de arquivos (NAS) + SaaS de RH	FGTS: 5 anos (STF, ARE 709.212/DF, repercussão geral); ASO e prontuário ocupacional: mínimo de 20 anos após o desligamento (NR-7, salvo prazo diverso nos anexos)	Backup diário, RBAC	Não	Médio
5	Recrutamento e seleção (RH)	Nome, e-mail, telefone, formação e histórico profissional	Não	Candidatos	Avaliação de perfil para vagas	Art. 7º, V	RH e gestor requisitante	E-mail do RH + Google Drive corporativo	6 meses, depois descarte	Acesso restrito ao RH, expurgo periódico	Sim (Google, EUA)	Baixo
6	Monitoramento por CFTV (Segurança)	Imagem facial, vídeo, data e horário	Não	Pacientes, colaboradores, prestadores e visitantes	Segurança patrimonial e física	Art. 7º, IX	Administração e empresa de monitoramento	NVR local + backup em nuvem do fornecedor	30 dias (gravação em loop)	Rack trancado, senha restrita à diretoria	Não	Médio
7	Newsletter e campanhas (Marketing)	Nome, e-mail, WhatsApp, data de aniversário	Não	Pacientes adultos e responsáveis legais	Orientações de saúde bucal e lembretes de check-up	Art. 7º, IX (com LIA documentado e opt-out)	Marketing e SaaS de e-mail marketing	Plataforma SaaS de automação	Até o descadastro	2FA, link de descadastro em 1 clique	Sim (SaaS, EUA)	Baixo
8	Atendimento via WhatsApp (Atendimento)	Nome, número do WhatsApp, histórico de conversas	Não	Pacientes e potenciais clientes	Dúvidas e triagem para agendamento	Art. 7º, V	Atendentes e provedor da API do WhatsApp	CRM SaaS; celulares corporativos e pessoais (BYOD parcial) integrados ao CRM	1 ano após o último contato	Bloqueio de tela, senha por aplicativo, backup criptografado	Sim (Meta, EUA)	Médio

#	Processo e área	Categorias de dados	Sensível?	Titulares	Finalidade	Base legal principal (LGPD)	Destinatários	Armazenamento	Retenção	Medidas de segurança	Transf. int.?	Risco
9	Gestão de contratos de fornecedores (Jurídico/Compras)	Nome do representante, CPF, RG, e-mail corporativo, assinatura	Não	Representantes de empresas contratadas	Formalização e gestão de contratos	Art. 7º, V	Administrativo/Jurídico e plataforma de assinatura	Nuvem corporativa + SaaS de assinatura eletrônica	5 anos após o fim do contrato (Código Civil, art. 206)	RBAC, logs de assinatura	Não	Baixo
10	Pesquisa de satisfação (Qualidade)	Nome, nota, comentários	Não	Pacientes atendidos	Melhoria da qualidade do atendimento	Art. 7º, IX	Qualidade e Administração	Formulário online (SaaS)	12 meses, depois anonimização	Acesso restrito à conta da empresa	Sim (SaaS, EUA)	Baixo

Em cada processo há uma base legal principal por categoria de dado. O processo 4 usa duas porque trata dados comuns (Art. 7º) e dados sensíveis (Art. 11).

3. Critérios de risco

O risco combina a probabilidade de incidente com o impacto sobre os titulares.

- **Baixo:** dados cadastrais simples, volume reduzido, sem compartilhamento amplo (pesquisa, recrutamento, contratos).
- **Médio:** dados financeiros, volume expressivo, vídeo contínuo ou atendimento em dispositivos móveis (faturamento, CFTV, WhatsApp, folha).
- **Alto:** dados de saúde em larga escala ou contínuos, e dados de crianças e adolescentes, onde vazamento pode causar discriminação, dano moral ou violação da intimidade (prontuários).

4. Pontos de atenção

- **Crianças e adolescentes (Art. 14):** a clínica atende odontopediatria e registra dependentes no RH. O tratamento deve seguir o melhor interesse do menor, com informação clara e ciência de ao menos um responsável legal. O consentimento específico só é necessário se a base escolhida for o consentimento.
- **Prontuários físicos (processo 2):** arquivo em papel sem registro de acessos, com risco de perda, descarte inadequado ou consulta indevida.
- **BYOD no WhatsApp (processo 8):** aparelhos pessoais em home office sem gestão de segurança (MDM).
- **Transferência internacional (processos 5, 7, 8 e 10):** provedores sediados nos EUA sem verificação de cláusulas-padrão conforme a Resolução CD/ANPD nº 19/2024.

- **Operadores sem DPA (processos 3, 4 e 6):** contabilidade, CFTV e RH sem aditivo de proteção de dados e notificação de incidentes.
- **Retenção:** currículos acumulados na caixa de e-mail do RH sem rotina de descarte.
- **CFTV:** sem placas informando monitoramento e finalidade.
- **Pesquisa de satisfação:** o campo livre pode receber dados de saúde digitados pelo paciente.
- **Marketing:** falta opt-out simples nas mensagens enviadas por WhatsApp.

5. Plano de ação

1. **Encarregado (Art. 41):** nomear formalmente e divulgar o contato no site.
2. **Canal do titular (Art. 18):** e-mail e formulário web para acesso, correção, eliminação e revogação.
3. **RIPD (Art. 38):** elaborar para anamnese e prontuário, pelo volume de dados de saúde e de menores.
4. **Resposta a incidentes (Art. 48):** fluxo de detecção, contenção, mitigação e notificação à ANPD e aos titulares.
5. **Operadores e dispositivos móveis:** aditivos DPA com fornecedores e política de BYOD com gestão de dispositivos.
6. **Política de retenção e descarte:** exclusão programada de currículos (6 meses) e anonimização das pesquisas (12 meses).
7. **CFTV:** instalar placas visíveis sobre o monitoramento e sua finalidade.
8. **Prontuário físico:** migrar gradualmente para meio eletrônico, respeitando os prazos de guarda da Lei 13.787/2018.
9. **Marketing:** documentar o teste de legítimo interesse (LIA) e garantir opt-out em todos os canais.

6. Metodologia e fontes

Simulação com cenário fictício, baseada em mapeamento de fluxo de dados (data flow mapping). O registro das operações segue o Art. 37 da LGPD, e cada processo foi vinculado a uma base legal dos Arts. 7º, 11 ou 14 da Lei nº 13.709/2018.

- LGPD (Lei nº 13.709/2018): Arts. 7º, 11, 14, 18, 37, 38, 41 e 48.
- ANPD: guia orientativo para agentes de tratamento e encarregado; guia de segurança da informação para agentes de pequeno porte; Resolução CD/ANPD nº 19/2024 (transferência internacional).
- Lei nº 13.787/2018 (prontuário eletrônico e prazo de guarda, art. 6º).

- NR-7 (PCMSO): guarda de prontuários ocupacionais por no mínimo 20 anos após o desligamento, salvo prazo diverso nos anexos.
- STF, ARE 709.212/DF (prescrição quinquenal do FGTS, repercussão geral).